

MEMORANDUM

Privileged & Confidential — Pre-Engagement Legal Risk Brief

TO:	Managing Partner, Client Organization	DATE:	April 23, 2026
FROM:	Governance Consultant, GRC Practice	FILE:	IT-157 / Phase 1
RE:	Legal Risk Exposure — Authorized Penetration Testing Engagement		

1. Purpose

This memorandum outlines the principal criminal and civil exposures that arise in any penetration testing engagement absent written authorization, and the contractual mechanism we will use to allocate residual risk. The controlling authorities are the federal Computer Fraud and Abuse Act (CFAA), 18 U.S.C. § 1030, and the Washington Cybercrime Act, Chapter 9A.90 RCW.

2. Five Prohibited Acts (Risk Ledger)

The following conduct is criminal when performed without the target organization's express, written authorization. Each carries independent federal and state exposure:

- 1. Unauthorized Access.** Intentionally accessing a computer, system, or database without permission, or exceeding the scope of permission granted. *CFAA § 1030(a)(2); RCW 9A.90.040 (felony if a government system or coupled with intent to commit another crime) and RCW 9A.90.050 (gross misdemeanor otherwise).*
- 2. Intentional Damage or Impairment.** Knowingly transmitting code, commands, or traffic that causes damage, data loss, or degraded availability — the risk posed by exploit payloads, fuzzing, or a mishandled denial-of-service test. *CFAA § 1030(a)(5); RCW 9A.90.060 (electronic data service interference); RCW 9A.90.080 (electronic data tampering).*
- 3. Trafficking in Passwords or Access Credentials.** Knowingly selling, sharing, or otherwise transferring passwords or access tokens that permit unauthorized entry into a protected system. This reaches credential dumps, hash lists, and session cookies captured during testing. *CFAA § 1030(a)(6).*
- 4. Electronic Data Theft.** Intentionally, and without authorization, obtaining or exfiltrating electronic data with intent to appropriate it — implicated the moment a tester copies client files, PII, or source code outside a pre-approved evidence channel. *RCW 9A.90.100; see also CFAA § 1030(a)(2) (obtaining information).*
- 5. Computer Fraud & Spoofing.** Accessing a system with intent to defraud, or impersonating another entity (domain, sender, identity) to induce reliance. Covers phishing pretexts and forged sender headers used outside an authorized social-engineering scope. *CFAA § 1030(a)(4); RCW 9A.90.070 (spoofing).*

3. State vs. Federal: One Key Distinction

The **CFAA** criminalizes mere unauthorized access that obtains information from a “protected computer” as a standalone federal offense — *no secondary criminal intent is required* (18 U.S.C. § 1030(a)(2)). Washington's cybercrime statute takes a tiered approach: unauthorized access only rises to **first-degree computer trespass (a Class C felony)** when the actor either (i) intends to commit a separate state-law crime or (ii) targets a government-maintained system; otherwise the conduct is charged as **second-degree computer trespass, a gross misdemeanor** (RCW 9A.90.040–.050). In short, the CFAA treats unauthorized access as inherently felonious, while Washington reserves felony treatment for aggravated circumstances.

4. Liability Mitigation: Indemnification & the “Get-Out-of-Jail-Free” Stack

Indemnification is a contractual risk-shifting clause in which the client agrees to hold the tester harmless from, and reimburse the tester for, losses arising out of good-faith performance within the agreed scope — including third-party claims, business-interruption costs, and incidental system damage (e.g., a service crash during a sanctioned scan). Standing alone, however, indemnification is insufficient. A defensible engagement stacks four controls: (a) a signed **Master Services Agreement** containing mutual indemnification and a negotiated liability cap; (b) a detailed **Rules of Engagement** that fixes scope, prohibited techniques, and escalation contacts; (c) a signed **Authorization-to-Test** letter carried by each technician as an affirmative defense against criminal trespass charges; and (d) **Errors & Omissions and Cyber Liability insurance** sized to the engagement. Together, these instruments convert conduct that would otherwise violate the CFAA and RCW 9A.90 into documented, authorized professional services.

This memorandum is provided for educational and engagement-planning purposes and does not constitute legal advice. Counsel should review all engagement documents prior to execution.